

Cas d'usage : pilier 2, gestion des incidents

Du score de criticité à quelques KPI mesurables

Kélian Kaddouri

20 juillet 2026

Pourquoi ce cas d'usage. Deux praticiens le confirment : la contagion dirigée entre piliers (W) n'est pas identifiable sur donnée réelle. C'est le verdict chiffré du script de faisabilité (placebo, $z \approx -0,1$), rejoint par le jugement métier de M. Cherkaoui. La cascade **reste le modèle normatif** (jugement d'expert assumé, analyse de sensibilité) ; on met le poids **empirique** là où la donnée existe. Choix retenu : **P2, gestion des incidents**, sur donnée open source, avec pour but de **traduire le score de criticité en KPI**.

Définir l'incident significatif : deux lentilles

Un incident déclenche l'obligation de gestion P2 s'il est **significatif**. Deux lectures complémentaires, chacune adossée à une source :

- **impact financier** : perte en euros au-dessus d'un seuil (SAS OpRisk) ;
- **impact réputationnel** : révélation publique et médiatisation (Data Breach Chronology).

Elles ne sélectionnent pas les mêmes incidents : un rançongiciel payé discrètement pèse en euros sans presse, une fuite de données pèse en presse sans perte directe. La maille P2 doit unir les deux, ce qui justifie un **score** plutôt qu'un simple montant.

Q : cas d'usage P2, le délai de notification comme KPI central

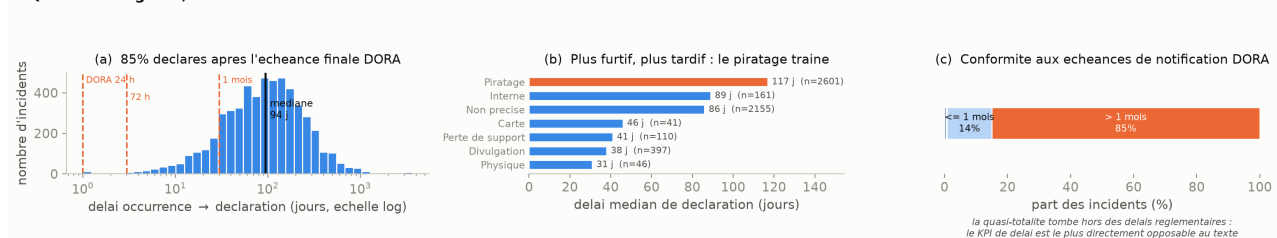


Figure 1. Socle empirique du cas P2 (secteur financier, Data Breach Chronology). Le **délai de notification** est le KPI le plus directement opposable à DORA : médiane de 94 jours, **85 % des incidents déclarés après l'échéance finale d'un mois**. Il croît avec la furtivité (piratage 117 j contre incident physique 31 j).

Traduire le score en KPI (la demande de M. Cherkaoui)

Le modèle donne une criticité = $f(\text{probabilité, gravité})$. Pour P2, chaque facteur se lit comme une quantité **observable** :

KPI	Valeur	Lecture DORA / métier	Source
Fréquence d'incidents	0,10 à 0,21 / entité / an	probabilité d'occurrence	08b (OpRisk)
Impact financier (queue)	indice $\xi \approx 0,90$	gravité, queue lourde	05 (OpRisk)
Délai de notification	médiane 94 j ; 85 % > 1 mois	conformité art. 19 DORA	08e (Breach)
Difficulté de détection	piratage 117 j / physique 31 j	délai selon furtivité	08e (Breach)
Accumulation tiers	20 % portés par causes communes	concentration (P4)	08d (Breach)

Le score abstrait devient un tableau de bord de quatre quantités observables. La *probabilité* du modèle s'incarne dans la **fréquence** ; la *gravité* dans l'**impact financier** et le **délai de notification** ; et l'accumulation par cause commune (un tiers qui tombe, plusieurs entités touchées) rejoint le pilier P4, que M. Cherkaoui désigne comme le point d'entrée le plus critique. Le délai est le plus précieux : personne ne le regarde sans la donnée, et il est directement opposable au texte réglementaire.

Caveats assumés. (1) `reported_date` est la révélation *publique* (notification d'État américain), pas la notification au superviseur au sens DORA : le délai mesuré est un **majorant illustratif**, valable pour comparer les types entre eux, non une mesure du délai réglementaire. (2) Donnée **américaine**, proxy d'entités soumises à DORA. (3) La tendance annuelle du délai est biaisée par la troncature à droite (un incident récent n'apparaît que s'il est déjà déclaré) : non présentée comme résultat. Figure produite par `08e_cas_usage_p2.py`.